

INFO5990 – Professional Practice in IT

Practice Questions and Answer Guide for Final Exam

Instructions

These questions are designed to help you **prepare for the final exam** by practising **descriptive and scenario-based questions** similar in style and depth to the actual exam.

- The questions are **for practice only** and serve as a **guide to understand exam expectations**.
- Read each scenario carefully, identify the **main issues, stakeholders, and frameworks**, and write your own response before checking the **Answer Guide**. For questions 1-7, only hints are provided, in the exam we are expecting detailed answers, as a sample we are providing sample detailed answers for the question 8 - 11.
- Use the guide to see the **expected structure and key ideas**, not to memorise answers.

Note: These are **not real exam questions**, but practising them will help you analyse scenarios, apply frameworks, and write confident, structured answers.

Question 1 – Professionalism in IT Practice (9 Marks)

You have joined **DataNova Solutions** as an IT consultant. The company recently expanded to handle multiple enterprise clients, but project outcomes are inconsistent because different teams interpret “professional behaviour” differently. A recent client complained about late communication and the casual handling of confidential information. Senior management wants to strengthen a culture of accountability and professionalism across all teams.

- Define what professionalism means in an IT context and explain why it matters for consultants. (3 marks)
- Identify two behaviours that demonstrate professional accountability in daily IT work. (3 marks)
- Suggest two practical initiatives DataNova can introduce to promote consistent professional practice. (3 marks)

Answer Guide

- IT professionalism means applying technical expertise ethically and responsibly to deliver reliable solutions that meet client needs. It builds trust and protects both clients and the organisation’s reputation.
- Examples include meeting deadlines and owning mistakes, communicating honestly about project progress, and maintaining client confidentiality.
- Introduce mandatory onboarding covering expected professional standards and create peer-feedback or mentoring programs to reinforce professional behaviour in real projects.

Question 2 – IT and Organisational Value**(8 Marks)**

BluePeak Manufacturing invested in new digital systems to automate inventory and finance workflows. After a year, productivity has not improved and costs have risen. Executives believe IT projects are launched without clear links to strategic goals. They ask you to explain how IT creates business value and how that value can be measured beyond automation alone.

- a) Explain two ways IT can generate organisational value beyond basic efficiency.

(3 marks)

- b) Describe two methods to align IT initiatives with business strategy. (3 marks)

- c) Suggest one quantitative metric to evaluate IT value creation. (2 marks)

Answer Guide

- a) IT enables data-driven decision-making and innovation (e.g., predictive maintenance, analytics). It also enhances collaboration through integrated systems.
- b) Use enterprise-architecture mapping and joint IT-business planning sessions to link projects to strategic objectives.
- c) Track ROI or productivity gain using key performance indicators tied to cost savings or customer satisfaction.

Question 3 – IT Lifecycle and Project Phases**(9 Marks)**

MetroTrans Logistics operates aging software to manage deliveries. Frequent crashes and data loss have increased customer complaints. Management plans a complete system replacement but wants assurance that the new solution will stay reliable through its entire lifecycle.

- a) Outline the main phases of the IT system lifecycle and their purpose. (3 marks)
- b) Explain two risks of skipping formal lifecycle steps. (3 marks)
- c) Recommend how regular lifecycle reviews help maintain system performance and cost control. (3 marks)

Answer Guide

INFO5990 Practice Questions for Final Exam

- a) Phases include planning, analysis, design, development, testing, implementation, operation, and retirement — each ensuring requirements are met and risks are managed.
- b) Skipping phases leads to undetected requirements errors and technical debt, causing cost overruns and failures.
- c) Regular reviews identify obsolescence and allow timely updates before major issues occur, reducing maintenance costs.

Question 4 – Project Management Approaches**(8 Marks)**

A university's IT department has traditionally used Waterfall for software projects.

However, stakeholders now demand frequent updates and faster delivery. Management is considering adopting Agile methods and needs to understand the trade-offs.

- a) Compare Agile and Waterfall approaches in terms of flexibility and stakeholder involvement. (3 marks)
- b) Explain how Agile reduces project risk compared to Waterfall. (3 marks)
- c) Identify one challenge when transitioning to Agile and suggest a solution.

(2 marks)

Answer Guide

- a) Agile uses short iterations and continuous feedback, while Waterfall follows a linear sequence. Agile is more adaptable to change.
- b) Frequent testing and client reviews detect issues early, reducing the risk of late failures.
- c) Teams may struggle with role changes; training and clear communication help build Agile mindsets.

Question 5 – Communication and Stakeholder Engagement (9 Marks)

During a major CRM upgrade at **Summit Finance**, developers focused on coding while ignoring end-user feedback. The system met technical requirements but frustrated staff who found it hard to use. The CIO asks for advice on improving stakeholder communication.

- a) Explain why communication is critical for successful IT projects. (3 marks)
- b) Identify two stakeholder groups and describe how communication can be tailored for each. (3 marks)
- c) Recommend one tool or method to ensure continuous feedback during development. (3 marks)

Answer Guide

INFO5990 Practice Questions for Final Exam

- a) Communication aligns expectations and prevents rework by ensuring all stakeholders share the same understanding of goals.
- b) Executives need summary dashboards for progress; end-users benefit from interactive demos and training sessions.
- c) Use collaboration platforms like Teams or regular scrum reviews to maintain two-way communication.

Question 6 – Stakeholder Communication and Influence (8 Marks)

TechBridge Solutions is delivering an ERP implementation across three departments. Early feedback shows poor collaboration. IT and Finance teams have different expectations, while HR feels left out of key decisions. Management has asked you to help identify communication priorities and improve stakeholder alignment.

- a) Using a **Power–Interest matrix**, classify the three stakeholder groups and explain how each should be managed. (3 marks)
- b) Suggest how the **SBAR (Situation–Background–Assessment–Recommendation)** framework could help structure progress communication to senior management. (3 marks)
- c) Recommend one digital collaboration tool or approach that would enhance cross-department engagement. (2 marks)

Answer Guide

- a) IT (high power, high interest) → manage closely; Finance (high power, medium interest) → keep satisfied; HR (low power, high interest) → keep informed.
- b) SBAR ensures concise, evidence-based updates → clarifies issues and recommendations for quick decisions.
- c) Use Teams channels or Asana boards for shared visibility and discussion threads.

Question 7 – Information and Estimation Accuracy

(8 Marks)

BrightEdge Analytics, a data-science consultancy, has been commissioned to build a machine-learning dashboard for a retail chain. The client insists on a fixed six-month deadline, but requirements are still evolving and some data sources are incomplete. Early estimates from different team leads vary by almost 40 percent, and senior management is worried about cost overruns. You have been asked to review the estimation process and recommend how to improve reliability while managing stakeholder expectations.

- a) Explain the role of estimation in IT project management and why accuracy is critical for BrightEdge's situation. (3 marks)
- b) Identify two common causes of estimation inaccuracy and describe how they can affect project outcomes. (3 marks)
- c) Recommend one estimation approach suitable for projects with incomplete requirements and justify why it fits this scenario. (3 marks)

Answer Guide

- a) Estimation provides forecasts for time, cost, and resources, forming the foundation for realistic schedules and budgets.

In BrightEdge's case, accurate estimation ensures client expectations, resource allocation, and profitability are balanced despite evolving requirements.

- b) **Unclear or changing requirements** – cause scope creep and rework, leading to schedule and cost overruns.

Optimism bias or lack of historical data – leads teams to underestimate effort, resulting in missed deadlines and client dissatisfaction.

- c) The **three-point estimation (PERT)** or **Delphi method** suits this case because they use expert judgment and probability to handle uncertainty. These approaches combine best-case, worst-case, and most-likely values (or collective expert consensus) to provide a more realistic, data-driven estimate

until clearer requirements emerge.

Practice Question 8 — CIA Triad, Vulnerabilities, and Secure Design

Scenario

A fintech startup develops a mobile banking application that allows customers to transfer money, check balances, and upload identity documents for verification.

During a security review, the following problems are discovered:

- Customer PINs are stored in plain text inside the database.
- Several transaction records were altered without authorization.
- The application crashes during high traffic periods on weekends.
- The mobile app accepts unvalidated input fields that are vulnerable to cross-site scripting (XSS) attacks.
- Management decides to release the application first and fix the issues in a future update.

(a) CIA Triad Application (3.5 marks)

Question

For each of the following principles, identify the related issue and explain its impact on the system:

- Confidentiality
- Integrity
- Availability

Detailed Sample Answer

Confidentiality

The issue related to confidentiality is that customer PINs are stored in plain text inside the database. Confidentiality focuses on protecting sensitive information from unauthorized access or disclosure. Storing PINs without encryption or hashing means that if attackers gain access to the database through hacking, insider misuse, or malware, they can immediately view customer credentials.

This creates a serious security risk because attackers could use stolen credentials to access customer accounts, perform fraudulent transactions, or commit identity theft. Financial institutions are expected to implement strong security protections because banking information is highly sensitive.

Integrity

The issue related to integrity is that transaction records were modified without authorization. Integrity ensures that data remains accurate, complete, and trustworthy throughout its lifecycle. Unauthorized modification means the system cannot guarantee that financial records are correct.

If attackers or unauthorized users can alter transaction records, customers may lose money, account balances may become inaccurate, and disputes may arise. This damages trust in the banking system and may lead to legal or financial consequences for the company.

Availability

The issue related to availability is that the application crashes during high traffic periods. Availability ensures that systems and services remain accessible to authorized users whenever needed.

If customers cannot access online banking services during busy periods, they may be unable to transfer money, pay bills, or verify transactions. Frequent downtime negatively affects customer satisfaction and may damage the company's reputation.

(b) Vulnerability Explanation (3 marks)

Question

Explain two vulnerabilities present in the system and describe how attackers could exploit them.

Detailed Sample Answer

Vulnerability 1 — Plain Text Password Storage

The application stores customer PINs in plain text instead of using secure hashing algorithms such as bcrypt or Argon2. This is a major vulnerability because plain text passwords can be directly read if attackers gain database access.

Attackers could exploit this vulnerability by compromising the database through malware, insider threats, SQL injection attacks, or stolen administrator credentials. Once attackers access the database, they can immediately view all customer PINs without needing to crack or decrypt them.

This could result in unauthorized banking access, identity theft, financial fraud, and large-scale compromise of customer accounts.

Vulnerability 2 — Cross-Site Scripting (XSS)

The application accepts user input without proper validation or sanitization, making it vulnerable to cross-site scripting attacks. XSS occurs when attackers inject malicious JavaScript code into web pages viewed by other users.

An attacker could exploit this vulnerability by submitting malicious scripts through input fields such as comments, forms, or profile sections. When another user opens the infected page, the malicious script executes in their browser.

This could allow attackers to steal session cookies, hijack user accounts, redirect users to phishing websites, or capture sensitive information entered into the application.

(c) Consequences of Deployment (3 marks)

Question

Discuss the likely consequences of deploying the system without fixing these issues for customers, employees, and the company.

Detailed Sample Answer

Deploying the banking application without fixing the identified security weaknesses could have severe consequences for all stakeholders.

For customers, compromised PINs and manipulated transaction records could result in financial losses, unauthorized account access, and identity theft. Customers may lose trust in the company's ability to protect sensitive financial information.

For employees and IT teams, security incidents could increase workload due to investigations, customer complaints, recovery efforts, and emergency patching activities. Staff morale may also decline if the company faces public criticism or regulatory action.

For the organization itself, the consequences may include reputational damage, customer loss, financial penalties, legal action, and non-compliance with security or privacy regulations. A major security breach in the banking sector can significantly damage customer confidence and reduce future business growth.

(d) Security Improvements (3 marks)

Question

Suggest two security improvements and justify how they would reduce the identified risks.

Detailed Sample Answer

Improvement 1 — Secure Password Hashing

The company should implement strong password hashing algorithms such as bcrypt, PBKDF2, or Argon2 combined with unique salts for every customer PIN.

Hashing converts passwords into irreversible cryptographic values, making it significantly harder for attackers to recover credentials even if the database is compromised. Salting further strengthens protection against rainbow table attacks and password cracking techniques.

Improvement 2 — Input Validation and Output Sanitization

The application should implement strict server-side input validation and output encoding to prevent malicious scripts from being injected into the system.

This security improvement reduces the risk of XSS attacks by ensuring that user-provided input is treated as plain text rather than executable code. Additional protections such as Content Security Policy (CSP) can further strengthen browser security.

Practice Question 9 — Incident Response and Disaster Recovery

Scenario

You are the cybersecurity coordinator for ShopFast, a large e-commerce company.

One evening, the security monitoring system detects suspicious behavior:

- A staff account logs in from an unusual foreign IP address.
- Thousands of customer payment records are downloaded within minutes.
- Multiple servers suddenly stop responding, and ransom notes appear on several systems.
- The security team delays containment because they are uncertain whether the activity is legitimate.
- The compromised account remains active for several hours.
- Backup systems exist, but the most recent backups also contain encrypted files.
- Employees are confused about who should coordinate communication and technical recovery.
- Customers cannot place orders and begin posting complaints on social media.

(a) Incident vs Disaster Understanding (3.5 marks)

Question

Identify:

- One incident response situation
- One disaster recovery situation

Explain why each belongs to its category.

Detailed Sample Answer

Incident Response Situation

The suspicious foreign login and mass download of customer payment records represent a cybersecurity incident response situation. Incident response focuses on identifying, investigating, containing, and minimizing the impact of security breaches or attacks.

This event indicates unauthorized access and possible data theft. Immediate actions such as disabling accounts, isolating systems, and analyzing logs are required to contain the attack and prevent further compromise.

Disaster Recovery Situation

The ransomware attack that caused servers to become unavailable represents a disaster recovery situation. Disaster recovery focuses on restoring critical systems, services, and operations after major disruptions.

Because multiple servers are encrypted and unavailable, the company must recover systems, restore backups, and resume business operations as quickly as possible.

(b) Response and Recovery Breakdown (3 marks)

Question

Identify two failures in how the organization handled:

- the cybersecurity incident, and
- the operational disruption.

Detailed Sample Answer

Failure 1 — Delayed Incident Containment

The security team delayed taking action because they were unsure whether the alert represented a real attack. This delay allowed attackers to continue accessing customer payment records and potentially spread ransomware further across the network.

Fast containment is critical during cybersecurity incidents because attackers often move quickly once they gain initial access.

Failure 2 — Poor Coordination and Leadership

Employees were confused about who should lead communication and technical recovery activities. This lack of coordination delayed response actions, increased downtime, and created confusion among customers and staff.

Organizations should have clearly defined incident response and disaster recovery roles to ensure rapid and organized decision-making during emergencies.

(c) Data and System Challenges (3 marks)

Question

Explain the challenges faced in containing the attack and restoring systems.

Detailed Sample Answer

One major challenge was that the compromised staff account remained active for several hours. This allowed attackers additional time to steal data, spread malware, and potentially compromise more systems.

Another challenge was that backup files were already encrypted or infected. This made system restoration difficult because reliable recovery copies were unavailable. Recovering systems from compromised backups increases downtime and operational disruption.

Additionally, customers were unable to place orders, which created financial losses and public complaints on social media. The organization therefore had to manage both technical recovery and reputational damage simultaneously.

(d) Integrated Improvement Strategy (3 marks)

Question

Recommend two improvements that would strengthen both incident response and disaster recovery processes.

Detailed Sample Answer

Improvement 1 — Formal Incident Response Plan

The company should establish a formal incident response plan with clearly assigned responsibilities, escalation procedures, communication protocols, and containment strategies.

This would enable faster decision-making during attacks and reduce confusion among staff members. Regular incident response exercises and simulations should also be conducted to improve preparedness.

Improvement 2 — Secure and Isolated Backup Strategy

The organization should implement offline, immutable, and regularly tested backups to ensure clean recovery points during ransomware incidents.

Backups should be separated from production systems so attackers cannot encrypt or modify them during an attack. Regular testing ensures that backup systems are functional and recovery procedures work effectively during emergencies.

Practice Question 10— CIA Triad, Vulnerabilities, and Secure Design

Scenario

An online learning platform used by multiple schools allows teachers to upload exams and students to submit answers online.

During testing, the IT team discovers:

- Student passwords are stored using weak hashing algorithms without salting.
- Some uploaded exam files were modified by unauthorized users.
- The website becomes unavailable during final exam periods due to excessive traffic.
- Search fields in the application are vulnerable to SQL injection attacks.
- The project manager argues that the issues are minor and can be addressed after deployment.

(a) CIA Triad Application (3.5 marks)

Question

Identify the issue related to each CIA principle and explain how it affects system security.

- Confidentiality
- Integrity
- Availability

Detailed Sample Answer

Confidentiality

The confidentiality issue in this scenario is the use of weak password hashing algorithms without salting. Confidentiality focuses on preventing unauthorized access to sensitive information such as student accounts and credentials.

Weak hashing algorithms are easier for attackers to crack using brute force or rainbow table attacks. Without salting, attackers can compare hashed passwords against precomputed databases to recover passwords quickly. If student accounts are compromised, attackers may access personal information, assessments, and grades.

Integrity

The integrity issue is that uploaded exam files were modified without authorization. Integrity ensures that information remains accurate, trustworthy, and unchanged unless modified by authorized users.

If exam files can be altered, students may receive incorrect exams, grades may become unreliable, or assessment materials could be tampered with. This undermines trust in the academic system and may create fairness and compliance concerns.

Availability

The availability issue is that the website becomes unavailable during final exam periods due to excessive traffic. Availability ensures that systems remain operational and accessible when users need them.

If students cannot access exams or submit assignments during critical periods, this may disrupt academic activities and negatively impact student performance. System downtime during assessments may also damage institutional credibility.

(b) Vulnerability Explanation (3 marks)

Question

Explain two vulnerabilities from the scenario and describe possible attack methods.

Detailed Sample Answer

Vulnerability 1 — Weak Password Hashing

The system uses weak hashing algorithms without salting for student passwords. Weak hashing methods such as MD5 or SHA-1 are vulnerable to cracking attacks because attackers can use rainbow tables or brute force tools to recover passwords.

An attacker who gains access to the password database may crack thousands of student credentials quickly. Compromised accounts may then be used to access sensitive academic records or impersonate students.

Vulnerability 2 — SQL Injection

The application is vulnerable to SQL injection because search fields accept unsanitized user input. SQL injection occurs when attackers insert malicious SQL commands into application inputs.

Attackers could exploit this vulnerability to bypass authentication, retrieve confidential student data, modify database records, or even delete important information. SQL injection is one of the most dangerous web application vulnerabilities because it directly targets backend databases.

(c) Consequences of Deployment (3 marks)

Question

Discuss the possible consequences for students, teachers, and the institution if the platform is deployed without resolving the security problems.

Detailed Sample Answer

For students, compromised accounts may expose personal information, submitted assignments, and academic records. Students may also lose access to exams during critical assessment periods due to system outages.

For teachers, modified exam files and compromised assessment materials may create academic integrity issues and increase workload due to re-evaluation and investigation activities.

For the institution, deploying an insecure platform could result in reputational damage, student complaints, legal consequences, and loss of trust in the online learning system. Security incidents in educational systems may also violate privacy regulations and institutional policies.

(d) Security Improvements (3 marks)

Question

Recommend two security controls or improvements and explain how they address the vulnerabilities.

Detailed Sample Answer

Improvement 1 — Strong Password Protection

The institution should implement secure password hashing algorithms such as bcrypt, PBKDF2, or Argon2 with unique salts for every password.

This significantly improves confidentiality because even if attackers access the password database, recovering passwords becomes extremely difficult.

Improvement 2 — Secure Database Queries

The development team should use parameterized queries and prepared statements instead of dynamically constructing SQL queries from user input.

This prevents attackers from injecting malicious SQL commands into application fields and greatly reduces the risk of SQL injection attacks.

Practice Question 11— Incident Response and Disaster Recovery

Scenario

CloudHealth Services provides cloud-based medical systems for several clinics and pharmacies.

During routine monitoring, the following events occur:

- An administrator account is used to access systems from an unfamiliar location.
- Large volumes of prescription records are copied and transferred externally.
- Shortly afterward, multiple databases become unavailable because malware encrypts system files.
- The incident response team delays action while verifying whether the alert is genuine.
- Staff members disagree about whether to prioritize recovery, communication, or forensic investigation.
- Backups are available, but some backup files were corrupted before detection.
- Clinics lose access to patient records and urgently request updates.

(a) Incident vs Disaster Understanding (3.5 marks)

Question

Identify:

- One incident response activity
- One disaster recovery activity

Explain why they belong to those categories.

Detailed Sample Answer

Incident Response Activity

The suspicious administrator login from an unfamiliar location and the external transfer of prescription records represent an incident response situation. Incident response focuses on identifying, investigating, and containing security breaches before they spread further.

This activity indicates possible unauthorized access and data exfiltration. Immediate containment actions such as disabling accounts, isolating systems, and analyzing security logs are necessary to limit damage.

Disaster Recovery Activity

The malware encryption causing databases to become unavailable represents a disaster recovery situation. Disaster recovery focuses on restoring critical systems, services, and business operations after significant disruptions.

Since healthcare clinics depend on continuous access to patient records, restoring systems quickly becomes essential for maintaining healthcare operations and patient safety.

(b) Response and Recovery Breakdown (3 marks)

Question

Explain two weaknesses in the organization's handling of:

- the cyberattack, and
- the service outage.

Detailed Sample Answer

Weakness 1 — Delayed Incident Response

The incident response team delayed taking action while verifying whether the alert was genuine. This delay allowed attackers additional time to steal prescription records and spread malware across systems.

Quick containment is critical in healthcare environments because delays may increase data exposure and disrupt patient care services.

Weakness 2 — Lack of Coordination

Staff members disagreed about whether to prioritize recovery, communication, or forensic investigation. This confusion slowed response efforts and increased operational disruption.

Without clearly defined leadership and procedures, organizations struggle to coordinate technical recovery, stakeholder communication, and evidence preservation during major incidents.

(c) Data and System Challenges (3 marks)

Question

Explain the major challenges faced when:

- containing the compromise, and
- restoring affected systems and data.

Detailed Sample Answer

One major challenge in containing the attack was identifying all compromised systems and accounts. Since attackers had already accessed administrative privileges, they may have moved laterally across the network and compromised additional systems.

Another major challenge involved restoring systems because some backup files were already corrupted before detection. Corrupted backups reduce recovery reliability and may increase downtime significantly.

The organization also faced pressure from clinics demanding immediate access to patient records. This created both technical and operational challenges because healthcare services depend heavily on continuous data availability.

(d) Integrated Improvement Strategy (3 marks)

Question

Recommend two coordinated improvements that would strengthen both incident response and disaster recovery readiness.

Detailed Sample Answer

Improvement 1 — Automated Threat Detection and Rapid Containment

The organization should implement advanced monitoring systems with automated threat detection and account isolation capabilities.

For example, suspicious overseas logins or abnormal data transfers could automatically trigger account suspension and security alerts. This would significantly reduce attacker dwell time and limit data exposure.

Improvement 2 — Secure Backup and Disaster Recovery Testing

The organization should maintain offline, immutable, and regularly tested backups. Backup systems should be isolated from production environments to prevent ransomware from encrypting backup files.

Regular disaster recovery exercises should also be conducted to verify that systems can be restored efficiently during emergencies. This improves operational resilience and reduces downtime during future incidents.